



CLIENT DELIVERABLE

SAOS Security Architecture v2.0

Systack Documentation

Table of Contents

SAOS Security Architecture v2.0

Overview

Security Stack Summary

1. Network Security

2. Authentication & Authorization

3. Backup & Recovery — P2

4. Security Events Monitoring — P3

5. Admin Console Hardening — P4

6. Compliance Package — P5

7. Data Protection

8. API Endpoint Reference

9. Database Schema (Security-Related Tables)

10. Roadmap

ROLE	COLOR	HEX
Headers, CTAs	Navy	 #001a2d
Navy Light	Navy Light	 #002845
Secondary accents	Teal	 #007da9
Primary buttons, links	Cyan	 #00a1db
Gradients	Cyan Bright	 #00c5e0
Backgrounds	Gray 50	 #f8fafc
Cards	Gray 100	 #f1f5f9
Borders	Gray 200	 #e2e8f0
Muted text	Gray 400	 #94a3b8
Body text	Gray 600	 #475569
Headings	Gray 800	 #1e293b

ROLE	COLOR	HEX
Success	Green	 #22c55e
Error	Red	 #ef4444
Accent highlights	Purple	 #8b5cf6

SAOS Security Architecture v2.0

Version: 2.0
Date: 2026-07-05
Author: SOL (System Operations Liaison)
Status: Active
Classification: Enterprise/Private

Overview

SAOS (Systack AI Operations System) security architecture provides defense-in-depth for customer-facing automation services. This document covers the complete security stack from network through application layer, including backup/recovery, security monitoring, audit systems, and compliance.

Security Stack Summary

LAYER	TECHNOLOGY	STATUS
Network	Tailscale WireGuard mesh VPN	 Active
Transport	TLS 1.3 via Tailscale	 Active
Authentication	PIN + TOTP MFA (RFC 6238)	 Active (P1)
Authorization	RBAC (5 roles, permission-based)	 Active (P1)
Rate Limiting	Per-endpoint, 8 configurations	 Active (P1)
Audit Logging	Full audit trail, 3-year retention	 Active
Backup & Recovery	pg_dump + restore verification	 Active (P2)
Security Monitoring	Event tracking, threat detection	 Active (P3)
Admin Audit Export	ZIP export, client audit reports	 Active (P4)
Compliance Package	5 policies, incident response, trust center	 Active (P5)

1. Network Security

1.1 Tailscale Mesh VPN

- All SAOS services accessible only via Tailscale encrypted tunnel
- WireGuard protocol — no public internet exposure

- Device-level authentication (device keys, not just passwords)
- No open ports on public interfaces

1.2 CORS Policy

- Restricted to: `localhost:8768` , `*.ts.net` , `systack.net`
- No wildcard CORS origins
- Preflight requests enforced

1.3 Internal API Security

- Internal endpoints require `X-Internal-API-Key` header
- Key stored in environment variable `SAOS_INTERNAL_API_KEY`
- Internal endpoints not exposed outside Tailscale

2. Authentication & Authorization

2.1 PIN Authentication

- 4-10 digit numeric PIN
- Stored in database with comparison hashing
- Rate limited: 5 attempts per 5 minutes per IP
- Temporary PINs for onboarding (24-hour expiry)
- PIN change revokes all active sessions

2.2 Multi-Factor Authentication (MFA) — P1

- TOTP RFC 6238 compliant (HMAC-SHA1, 6 digits, 30s period)
- 8 one-time recovery codes (hex format)
- Compatible with Google Authenticator, Authy, 1Password
- Endpoints: setup, verify, disable, status
- MFA code required at login when enabled
- Recovery codes consumed on use

2.3 Role-Based Access Control (RBAC) — P1

ROLE	DASHBOARD	TASKS	CHAT	BILLING	ADMIN	USERS	ALL CLIENTS
customer	✓	✓	✓	✗	✗	✗	✗
support	✓	✓	✓	✗	✗	✗	✓
billing	✓	✗	✗	✓	✗	✗	✗
ops	✓	✓	✗	✗	✗	✗	✓
admin	✓	✓	✓	✓	✓	✓	✓

- `require_role()` decorator for endpoint protection
- `require_permission()` decorator for granular access
- All access denials logged to `audit_log` + `security_events`

2.4 Session Management

- Bearer token authentication
- Tokens: `secrets.token_urlsafe(32)` — 32 bytes of entropy
- Token hash: SHA-256
- Expiry: 30 days
- Revocation: on logout, PIN change, or admin action
- One token per session (no session sharing)

2.5 Rate Limiting — P1

ENDPOINT TYPE	MAX	WINDOW	HEADERS
login	5	5 min	Retry-After, X-RateLimit-*
mfa_verify	5	5 min	Retry-After, X-RateLimit-*
pin_reset	3	1 hour	Retry-After, X-RateLimit-*
register	5	1 hour	Retry-After, X-RateLimit-*
api_general	100	1 min	X-RateLimit-*
api_write	30	1 min	X-RateLimit-*
webhook	200	1 min	—
file_upload	10	1 min	—

3. Backup & Recovery — P2

3.1 Backup Strategy

- **Type:** `pg_dump` (full database export)
- **Frequency:** Daily (manual or via script)
- **Location:** `~/saos-backups/` (local, encrypted filesystem)
- **Format:** SQL (plain text, human-readable)
- **Retention:** 30 days rolling

3.2 Restore Verification

- Script: `scripts/backup_verify.py`
- Process:
 1. `pg_dump` → backup file
 2. SHA-256 checksum calculation
 3. Create temporary test database
 4. Restore backup to test DB
 5. Run verification queries (table existence, record counts)
 6. Drop test database
 7. Log results to `backup_log` table

3.3 Recovery Objectives

METRIC	TARGET	ACTUAL
RPO (Recovery Point Objective)	24 hours	24 hours (daily backup)
RTO (Recovery Time Objective)	10 minutes	~3 minutes (verified)

3.4 Backup Log Table

- All backup operations logged to `backup_log` table
- Tracks: type, status, file path, size, checksum, verification result, RPO/RTO
- Queryable via `/api/admin/backup-log`

4. Security Events Monitoring — P3

4.1 Security Events Table

- Table: `security_events`
- Tracks: failed logins, rate limit hits, MFA failures, access denials, suspicious activity
- Severity levels: info, warning, critical
- Resolution tracking with notes and resolver

4.2 Automatic Event Logging

- Failed login attempts → `failed_login` event (warning)
- Rate limit hits → `rate_limit_hit` event (warning)
- MFA failures → `mfa_failure` event (warning)
- Access denials → `access_denied` event (warning)
- All events include IP, user agent, and context details

4.3 Dashboard Endpoints

- GET `/api/admin/security-events` — List with filtering (severity, type, resolved)
- GET `/api/admin/security-events/stats` — 30-day aggregated statistics
- POST `/api/admin/security-events/<id>/resolve` — Resolve event with notes

4.4 Statistics Tracked

- Events by type (30-day rolling)
- Events by severity
- Unresolved count
- Top offending IP addresses
- Critical unresolved events

5. Admin Console Hardening — P4

5.1 Audit Trail

- All actions logged to `audit_log` table
- 3-year retention (per data retention policy)
- Fields: `client_id`, `action`, `entity_type`, `entity_id`, `old_value`, `new_value`, `IP`, `user_agent`

5.2 Audit Export System

- `POST /api/admin/audit/export` — Export audit trail as ZIP
- Supports filtering by client, date range, action type
- Export includes: `audit_log.json`, `security_events.json`, `export_summary.json`
- SHA-256 checksum on every export
- All exports logged to `audit_exports` table

5.3 Client Audit Reports

- `GET /api/admin/audit/client/<id>` — Full client audit profile
- Includes: audit logs, security events, login history
- Available to admin and support roles

5.4 Audit Export Log

- Table: `audit_exports`
- Tracks: who exported, what type, date range, record count, file size, checksum
- Provides chain of custody for compliance audits

6. Compliance Package — P5

6.1 Compliance Policies

POLICY TYPE	TITLE	VERSION
security	Information Security Policy	1.0
data_retention	Data Retention Policy	1.0
incident_response	Incident Response Procedure	1.0
privacy	Privacy & Data Protection Policy	1.0
access_control	Access Control Policy	1.0

6.2 Policy Management

- Stored in `compliance_policies` table
- Versioned with effective dates and review dates
- Status: active, draft, deprecated
- Endpoints: list all, get by type
- Review cycle: quarterly or post-incident

6.3 Incident Response

Severity Levels

LEVEL	DESCRIPTION	RESPONSE TIME
P1	Critical — data breach, total outage	15 minutes
P2	High — partial outage, security event	1 hour
P3	Medium — degraded service	4 hours
P4	Low — minor issue	Next business day

Incident Log

- Table: `incident_log`
- Tracks: type, severity, title, description, affected clients, status, root cause, resolution, preventive measures, duration
- Endpoints: list, create, resolve
- Post-mortem required for P1/P2 incidents

6.4 Trust Center

- GET `/api/compliance/trust-center` — Public endpoint (no auth)
- Returns: security posture, compliance policies, recent incidents, backup status, security events summary
- Suitable for customer-facing trust page
- No sensitive data exposed

7. Data Protection

7.1 Data Residency

- All data stored on servers in United States (Dallas, TX)
- No cloud data residency outside US
- Backups stored locally on encrypted media

7.2 Encryption

- In transit: TLS 1.3 via Tailscale WireGuard tunnel
- At rest: filesystem-level encryption (AES-256 equivalent)
- Tokens: SHA-256 hashed
- MFA secrets: base32 encoded, stored in database

7.3 Data Export

- Customers can export all their data: `POST /api/export/data`
- ZIP format: tasks, chat, deliverables, settings
- No admin intervention required
- GDPR-style right to portability

7.4 Data Deletion

- Customers can request account deletion

- Data purged within 30 days
- Backups containing deleted data purged on next rotation

8. API Endpoint Reference

P2: Backup & Recovery

METHOD	ENDPOINT	AUTH	DESCRIPTION
GET	/api/admin/backup-log	admin, ops	Backup history
POST	/api/admin/backup/run	admin, ops	Trigger backup verification
GET	/api/admin/backup/rpo-rto	admin, ops	RPO/RTO metrics

P3: Security Events

METHOD	ENDPOINT	AUTH	DESCRIPTION
GET	/api/admin/security-events	admin, ops, support	List events
GET	/api/admin/security-events/stats	admin, ops, support	Aggregated stats
POST	/api/admin/security-events/<id>/resolve	admin, ops	Resolve event

P4: Admin Audit

METHOD	ENDPOINT	AUTH	DESCRIPTION
GET	/api/admin/audit-log	admin	Full audit trail
POST	/api/admin/audit/export	admin	Export audit ZIP
GET	/api/admin/audit/client/<id>	admin, support	Client audit report

P5: Compliance

METHOD	ENDPOINT	AUTH	DESCRIPTION
GET	/api/compliance/policies	any auth	List policies
GET	/api/compliance/policies/<type>	any auth	Policy by type
GET	/api/compliance/incidents	admin, ops, support	List incidents
POST	/api/compliance/incidents	admin, ops	Create incident
POST	/api/compliance/incidents/<id>/resolve	admin, ops	Resolve incident
GET	/api/compliance/trust-center	public	Trust center info

9. Database Schema (Security-Related Tables)

TABLE	PURPOSE
saos_clients	Client accounts with PIN, MFA, role
saos_roles	RBAC role definitions with permissions
client_auth_tokens	Session tokens with expiry and revocation
audit_log	Full audit trail (3-year retention)
security_events	Security event tracking with resolution
backup_log	Backup history with verification results
audit_exports	Audit export log for chain of custody
compliance_policies	Compliance policy documents
incident_log	Incident response tracking
notifications	Async notification queue

10. Roadmap

PRIORITY	ITEM	STATUS
P1	MFA (TOTP)	✅ Complete
P1	RBAC (5 roles)	✅ Complete
P1	Advanced Rate Limiting	✅ Complete
P2	Backup verification + restore drills	✅ Complete
P3	Security events dashboard	✅ Complete
P4	Admin console hardening + audit export	✅ Complete
P5	Compliance package + trust center	✅ Complete
—	iOS Safari cert trust (Cloudflare Tunnel)	⌚ Awaiting decision
—	Production deployment (dev → prod)	⌚ Pending
—	Monitoring dashboard (agent health)	⌚ Pending
—	Client onboarding flow automation	⌚ Pending
—	Billing integration (Stripe)	⌚ Pending

This document is updated as security features are added. Last updated: 2026-07-05 by SOL.